

SUPPORT DE COURS COMPLET

Gouvernance et gestion des risques de la sécurité de l'information

10h CM · 8h TP · 18h

Dr. Zakaria Sawadogo

École Polytechnique de Ouagadougou

Sommaire

Syllabus

1. Chapitre 1 — Introduction à la gouvernance de la sécurité de l'information
2. Chapitre 2 — Méthodologies d'analyse de risques
3. Chapitre 3 — Traitement du risque, PSSI et continuité d'activité
4. Chapitre 4 — Pilotage, indicateurs et conformité réglementaire

Gouvernance et gestion des risques de la sécurité de l'information

Volume horaire : 10h CM · 8h TP (18h)

Objectifs pédagogiques

- Comprendre le rôle de la gouvernance dans la sécurité de l'information (organisation, responsabilités, pilotage).
- Maîtriser une méthodologie d'analyse de risques (EBIOS RM et/ou ISO 27005) et savoir l'appliquer à un cas concret.
- Élaborer les documents structurants d'une démarche SSI : politique de sécurité (PSSI), plan de traitement du risque, plan de continuité d'activité.
- Construire des indicateurs de pilotage pertinents pour le suivi de la sécurité dans la durée.

Prérequis

Aucun prérequis technique strict ; ce module se combine naturellement avec *Audit organisation et technique* (l'audit alimente et vérifie la démarche de gestion des risques).

Plan de séances

Cours magistraux (10h)

Séance	Chapitre	Durée
1	Introduction à la gouvernance de la sécurité de l'information	2h
2	Méthodologies d'analyse de risques	3h
3	Traitement du risque, PSSI et continuité d'activité	3h
4	Pilotage, indicateurs et conformité réglementaire	2h

Travaux pratiques (8h)

Séance	Sujet	Durée
1	Cartographie des actifs et identification des menaces	2h
2	Analyse de risque EBIOS RM sur cas d'étude	2h
3	Élaboration d'une politique de sécurité (PSSI)	2h
4	Construction d'un tableau de bord SSI	2h

Évaluation

- TP notés (dossier de cas d'étude filé sur les 4 séances) : 50 %
- Examen final : 50 %

Bibliographie

- ANSSI, *La méthode EBIOS Risk Manager*.
- ISO/IEC 27005:2022 — Gestion des risques liés à la sécurité de l'information.
- ISO 22301 — Management de la continuité d'activité.
- NIST SP 800-30 — Guide for Conducting Risk Assessments.

Chapitre 1 — Introduction à la gouvernance de la sécurité de l'information

1. Définition de la gouvernance SSI

La gouvernance de la sécurité de l'information désigne l'ensemble des structures, processus et mécanismes de décision qui permettent à une organisation de définir, piloter et faire évoluer sa stratégie de sécurité, en cohérence avec ses objectifs métiers et son appétence au risque. Elle se distingue de la sécurité opérationnelle (mise en œuvre technique quotidienne) par son niveau : la gouvernance définit le « quoi » et le « pourquoi », l'opérationnel exécute le « comment ».

Il est utile de distinguer trois niveaux imbriqués, souvent confondus par les étudiants et parfois par les praticiens eux-mêmes :

- **Le niveau stratégique (gouvernance)** : il fixe les orientations, valide l'appétence au risque, alloue les ressources et rend compte aux instances de gouvernance (conseil d'administration, comité exécutif). Il répond à la question « où voulons-nous aller et combien sommes-nous prêts à investir ? ».
- **Le niveau tactique (management de la sécurité)** : il traduit les orientations stratégiques en programme d'action — politique, gestion des risques, plan de traitement, tableaux de bord. C'est le niveau du RSSI en tant que chef d'orchestre.
- **Le niveau opérationnel (sécurité technique)** : il met en œuvre concrètement les mesures — configuration des pare-feux, durcissement des systèmes, réponse aux alertes, gestion des correctifs.

Cette distinction est fondamentale : un déficit de gouvernance ne se corrige jamais uniquement par des moyens techniques supplémentaires. Une organisation peut disposer d'outils de sécurité performants (antivirus, pare-feu de nouvelle génération, SIEM) et rester néanmoins vulnérable si personne, au niveau stratégique, n'a défini de priorités claires, alloué de budget récurrent ou assigné de responsabilités précises. À l'inverse, une gouvernance solide sans compétence technique suffisante reste également insuffisante : la gouvernance encadre et oriente l'action technique, elle ne s'y substitue pas.

1.1 Gouvernance SSI et gouvernance d'entreprise

La gouvernance de la sécurité de l'information n'est pas une discipline isolée : elle s'inscrit dans la gouvernance globale de l'organisation, au même titre que la gouvernance financière ou la gouvernance des risques opérationnels. Cet ancrage a une conséquence pratique importante : le RSSI doit être capable de traduire des enjeux techniques (une vulnérabilité, un incident, une dette technique) en langage de gestion des risques compréhensible par des décideurs non spécialistes — impact financier potentiel, probabilité, comparaison avec d'autres risques de l'organisation (risque de change, risque juridique, risque de réputation). C'est ce travail de traduction qui légitime la place de la sécurité dans les instances de décision.

2. Pourquoi la sécurité doit être gouvernée et non seulement « techniquement gérée »

- La sécurité a un coût et engage des arbitrages (budget, ressources humaines, priorités) qui relèvent de décisions de direction, pas seulement d'équipes techniques.
- Un incident de sécurité majeur a des conséquences qui dépassent l'informatique (juridiques, financières, réputationnelles) : la direction doit être impliquée dans l'appétence au risque acceptée.
- Sans portage par la direction, les recommandations issues des audits (module précédent) restent rarement suivies d'effet.
- La sécurité entre en tension avec d'autres objectifs légitimes de l'organisation (rapidité de mise sur le marché, simplicité d'usage, coûts maîtrisés) : seule une instance de gouvernance disposant d'une vision transverse peut arbitrer ces tensions de façon cohérente, plutôt que de laisser chaque équipe technique trancher isolément selon ses propres priorités.
- La sécurité est par nature transversale : un même risque (par exemple la compromission d'un compte à privilèges) peut engager simultanément le DSI, les ressources humaines, le service juridique et la communication. Seule une gouvernance formalisée permet de coordonner ces acteurs avant qu'un incident ne survienne, plutôt que de les découvrir au moment de la crise.

2.1 Illustration pédagogique (cas fictif)

Considérons une organisation fictive, la Société Fictive de Services Financiers (SFSF), qui souhaite illustrer ce principe. Le responsable technique constate qu'un système hérité (legacy) n'est plus supporté par son éditeur et présente des vulnérabilités connues. Sans structure de gouvernance, ce constat reste un ticket technique parmi d'autres, noyé dans le flux quotidien, et le risque n'est jamais explicitement arbitré. Avec une gouvernance SSI structurée, ce constat est formalisé en risque (probabilité d'exploitation, impact potentiel sur la continuité des opérations), inscrit au registre des risques, présenté en comité de pilotage sécurité, puis arbitré par la direction qui décide, en toute connaissance de cause, d'un calendrier de migration et d'un budget associé. La différence n'est pas la détection du problème — un technicien compétent l'aurait identifié dans les deux cas — mais la capacité de l'organisation à transformer ce constat en décision documentée et suivie.

3. Les rôles clés

Rôle	Responsabilité principale
Direction générale	définit l'appétence au risque, arbitre les budgets, porte la culture sécurité
RSSI (Responsable de la Sécurité des Systèmes d'Information)	pilote la stratégie SSI, anime la gouvernance, rapporte à la direction
DSI	met en œuvre les moyens techniques, souvent en tension avec le RSSI sur les priorités (disponibilité vs sécurité)
Propriétaires de processus métier (business owners)	identifient la valeur et la criticité des actifs qu'ils exploitent, arbitrent le traitement du risque sur leur périmètre
Correspondants sécurité / DPO	relais opérationnels, conformité réglementaire (protection des données)

Un point de vigilance de gouvernance fréquent : le RSSI, pour rester indépendant, ne devrait idéalement pas être rattaché hiérarchiquement à la DSI qu'il est censé challenger. Un rattachement direct à la direction générale, à la direction des risques ou à la direction juridique est souvent préféré dans les organisations matures, précisément pour éviter qu'un même responsable (le DSI) n'arbitre à la fois la performance opérationnelle des systèmes (dont il est comptable) et le niveau d'exigence sécurité qui peut la contraindre (délais de mise en production, coûts de durcissement, disponibilité). Ce choix de rattachement n'est cependant pas universel : dans de plus petites structures, où les ressources ne permettent pas de multiplier les lignes hiérarchiques, un compromis pragmatique consiste à garantir au RSSI un accès direct et régulier à la direction générale, même s'il reste administrativement rattaché à la DSI.

3.1 Le RSSI : un rôle de traduction et d'influence plus que d'exécution directe

Contrairement à une idée reçue, le RSSI ne « fait » généralement pas la sécurité au sens de la configuration technique des systèmes — cette responsabilité incombe aux équipes DSI et aux administrateurs. Son rôle est davantage celui d'un animateur transversal : il définit la stratégie, anime la gouvernance des risques, propose des arbitrages à la direction, sensibilise les métiers et vérifie, via des indicateurs et des audits, que les mesures décidées sont effectivement mises en œuvre. Cette dimension d'influence sans autorité hiérarchique directe sur les équipes techniques explique pourquoi le soutien explicite de la direction générale est une condition de succès quasi systématique du poste.

4. Les composantes d'un système de gouvernance SSI

- Politique de sécurité (PSSI)** : document de référence formalisant les orientations, principes et responsabilités.
- Organisation** : comités de pilotage, instances de décision, circuits d'escalade.
- Gestion des risques** : méthodologie d'identification, d'évaluation et de traitement des risques (chapitre 2).
- Conformité** : suivi des obligations légales, réglementaires et contractuelles.
- Pilotage et amélioration continue** : indicateurs, tableaux de bord, audits internes, revues de direction.

Ces cinq composantes ne fonctionnent pas de manière isolée : elles forment un système cohérent où chaque élément nourrit les autres. La politique de sécurité fixe le cadre dans lequel la gestion des risques opère ; les résultats de la gestion des risques alimentent le plan de traitement et, par extension, les priorités budgétaires ; le suivi de conformité fournit une partie des exigences que la gestion des risques doit couvrir ; et le pilotage par indicateurs permet de vérifier, dans la durée, que l'ensemble du dispositif produit les effets attendus. Un système de gouvernance qui ne comporterait qu'une politique bien rédigée, sans mécanisme de suivi ni de mesure de son application effective, resterait un exercice largement théorique.

4.1 Les instances de gouvernance en pratique

Au-delà des documents, la gouvernance SSI se matérialise concrètement par des instances qui se réunissent à intervalles réguliers, avec un ordre du jour et des comptes rendus formalisés. On distingue typiquement :

Instance	Fréquence usuelle	Composition	Objet
Comité de sécurité opérationnel	mensuelle	RSSI, correspondants sécurité, équipes techniques	suivi des incidents, des vulnérabilités, avancement des actions correctives
Comité de pilotage SSI	trimestrielle	RSSI, DSI, représentants métiers	arbitrages sur le plan de traitement des risques, suivi des indicateurs
Revue de direction	annuelle (a minima)	direction générale, RSSI, DSI	validation de la stratégie, de l'appétence au risque, allocation budgétaire (voir chapitre 4)

Cette cascade d'instances permet de faire remonter l'information pertinente à chaque niveau sans noyer la direction générale dans des détails opérationnels, tout en garantissant que les décisions prises au sommet redescendent effectivement vers les équipes chargées de les exécuter.

5. Cadres de référence en gouvernance SSI

- **ISO/IEC 27001** : SMSI (système de management de la sécurité de l'information), avec un accent fort sur le pilotage par la direction (clause 5) et une exigence explicite d'amélioration continue.
- **COBIT** (Control Objectives for Information and Related Technologies) : cadre de gouvernance des systèmes d'information au sens large, incluant la sécurité, qui distingue explicitement gouvernance (orientation, supervision) et management (planification, réalisation, suivi) — une distinction très proche de celle introduite en section 1.
- **NIST Cybersecurity Framework** : structure la gouvernance autour de fonctions couvrant l'identification des risques, la protection, la détection, la réponse et la reprise après incident, largement adoptée au-delà du contexte américain pour sa simplicité de communication auprès de publics non techniques.

Ces cadres ne sont pas concurrents mais complémentaires : une organisation peut, par exemple, structurer son SMSI selon ISO 27001 pour viser une certification, tout en utilisant le vocabulaire du NIST Cybersecurity Framework pour communiquer plus simplement avec sa direction générale sur son niveau de maturité global. Le choix dépend souvent du secteur d'activité, du contexte réglementaire et des exigences des partenaires ou clients (certains appels d'offres exigent explicitement une certification ISO 27001, par exemple).

6. Maturité et amélioration continue

La gouvernance SSI n'est pas un état figé : elle progresse par cycles (souvent modélisés en PDCA — Plan, Do, Check, Act). Une organisation immature réagit aux incidents au coup par coup ; une organisation mature anticipe par une gestion structurée des risques et ajuste ses priorités sur la base d'indicateurs et de retours d'expérience.

6.1 Modèles de maturité

Pour objectiver ce niveau de maturité plutôt que de rester dans une appréciation subjective, de nombreuses organisations utilisent des grilles d'évaluation à plusieurs niveaux, inspirées des modèles de maturité de type CMM (Capability Maturity Model), adaptés à la sécurité de l'information. Un exemple pédagogique simplifié à cinq niveaux :

Niveau	Intitulé	Caractéristique typique
1	Initial / ad hoc	pas de processus formalisé, actions réactives, dépendance de quelques individus clés
2	Reproductible	premières pratiques documentées, mais appliquées de façon inégale selon les équipes
3	Défini	processus formalisés et communiqués à l'échelle de l'organisation (PSSI, gestion des risques)
4	Piloté	processus mesurés par des indicateurs, décisions fondées sur des données
5	Optimisé	amélioration continue institutionnalisée, anticipation proactive des risques émergents

Ce type de grille sert avant tout d'outil de dialogue avec la direction : elle permet de situer objectivement l'organisation, de fixer une cible réaliste (viser le niveau 5 partout n'est ni possible ni toujours pertinent) et de prioriser les investissements sur les domaines où l'écart de maturité est le plus risqué au regard des enjeux métier.

6.2 Le cycle PDCA appliqué à la gouvernance SSI

Le cycle PDCA, popularisé en gestion de la qualité puis repris par l'ISO 27001, structure l'amélioration continue en quatre phases répétées :

- **Plan** : établir le contexte, identifier les risques, définir les objectifs et le plan de traitement.
- **Do** : mettre en œuvre les mesures décidées (déploiement technique, formation, procédures).
- **Check** : vérifier l'efficacité des mesures via audits, indicateurs, tests.
- **Act** : ajuster la stratégie, corriger les écarts constatés, et relancer un nouveau cycle.

Ce cycle n'est pas un événement ponctuel mais un rythme continu de l'organisation : c'est précisément cette récurrence qui distingue une gouvernance mature d'une démarche de conformité ponctuelle réalisée uniquement à l'approche d'un audit ou d'une certification.

À retenir

- La gouvernance SSI relève de la direction, pas uniquement des équipes techniques : elle arbitre l'appétence au risque et les moyens alloués, et articule trois niveaux (stratégique, tactique, opérationnel).
- Un RSSI efficace a besoin d'un positionnement organisationnel qui préserve son indépendance vis-à-vis de la DSI, et joue avant tout un rôle de traduction et d'animation transversale plutôt que d'exécution technique directe.
- La gouvernance s'appuie sur un cycle continu : politique, gestion des risques, conformité, pilotage, amélioration — matérialisé par des instances régulières (comité opérationnel, comité de pilotage, revue de direction).

- Des cadres de référence reconnus (ISO/IEC 27001, COBIT, NIST Cybersecurity Framework) et des modèles de maturité permettent de structurer et d'objectiver la démarche plutôt que de la laisser dépendre d'appréciations subjectives.
- La maturité d'une gouvernance SSI se mesure et progresse par cycles (PDCA) ; elle n'est jamais définitivement acquise.

Chapitre 2 — Méthodologies d'analyse de risques

1. Vocabulaire de base de la gestion des risques

Terme	Définition
Actif (asset)	tout élément ayant de la valeur pour l'organisation (donnée, système, processus, image)
Menace	événement potentiel pouvant porter atteinte à un actif (attaque, erreur humaine, panne, catastrophe naturelle)
Vulnérabilité	faiblesse exploitable par une menace
Risque	combinaison de la probabilité qu'une menace exploite une vulnérabilité et de l'impact qui en résulterait
Mesure de sécurité (contrôle)	action réduisant la probabilité et/ou l'impact d'un risque
Risque résiduel	risque subsistant après application des mesures de sécurité

Formule couramment utilisée pour qualifier un risque : **Risque = Probabilité × Impact** (souvent affinée par des échelles qualitatives à 3-5 niveaux plutôt qu'un calcul numérique naïf).

Il est important de noter que cette formule, bien qu'omniprésente dans la littérature et les outils pratiques, est une simplification. Elle suppose implicitement une indépendance entre probabilité et impact, alors qu'en réalité ces deux dimensions peuvent être corrélées (un attaquant très motivé, donc rendant l'occurrence plus probable, vise souvent des cibles à fort impact). Elle ne rend pas compte non plus de la vitesse de propagation d'un risque, ni de sa capacité à se combiner avec d'autres risques (effet de cascade). Ces limites justifient que les méthodologies structurées présentées dans ce chapitre ne se contentent pas d'un simple produit arithmétique, mais organisent une réflexion plus riche autour du contexte, des sources de menace et des scénarios plausibles.

1.1 Distinguer risque brut, risque net et risque résiduel

La terminologie de la gestion des risques distingue plusieurs états successifs d'un même risque, une distinction essentielle pour éviter les confusions fréquentes en TP :

- **Risque brut (ou inhérent)** : niveau de risque en l'absence de toute mesure de sécurité — c'est un état théorique, utile pour hiérarchiser les enjeux avant traitement.
- **Risque net (ou actuel)** : niveau de risque compte tenu des mesures de sécurité déjà en place au moment de l'analyse.
- **Risque résiduel** : niveau de risque restant après la mise en œuvre des mesures de traitement additionnelles décidées à l'issue de l'analyse (voir chapitre 3).

Une erreur fréquente chez les débutants consiste à évaluer un risque « à froid » (brut) puis à décider de le traiter sans jamais formaliser explicitement le risque net de départ, ce qui empêche ensuite de mesurer objectivement l'efficacité des mesures ajoutées.

1.2 Approche par les actifs, approche par la menace

Deux logiques structurent historiquement l'analyse de risques, et il est utile de les distinguer avant d'aborder les méthodes concrètes :

- **L'approche par les actifs** part d'un inventaire des biens à protéger (données, systèmes, processus), évalue leur criticité, puis identifie les menaces et vulnérabilités qui pèsent sur chacun. Elle est exhaustive mais peut devenir lourde sur un système d'information étendu, et risque de diluer l'attention sur des scénarios peu réalistes.
- **L'approche par la menace (ou par les scénarios)** part des sources de risque plausibles (attaquant, concurrent, erreur interne) et de leurs objectifs, puis reconstruit les chemins d'attaque susceptibles d'atteindre les actifs critiques. Elle est plus ciblée et opérationnelle, mais dépend de la capacité des analystes à anticiper des scénarios réalistes.

Comme on le verra, EBIOS RM privilégie la seconde approche tandis qu'ISO 27005 reste plus proche de la première, ce qui explique en partie leur complémentarité plutôt que leur substituabilité.

2. EBIOS Risk Manager (méthode ANSSI)

EBIOS RM structure l'analyse en cinq ateliers :

1. **Cadrage et socle de sécurité** : périmètre de l'étude, missions et valeurs métier, événements redoutés, socle de mesures de sécurité déjà en place.
2. **Sources de risque** : identification des sources de risque (attaquant opportuniste, concurrent, État, initié malveillant) et de leurs objectifs visés.

3. **Scénarios stratégiques** : chemins d'attaque à haut niveau, cartographie de l'écosystème (fournisseurs, partenaires comme vecteurs indirects).
4. **Scénarios opérationnels** : déroulé technique détaillé d'une attaque, mode opératoire probable.
5. **Traitement du risque** : synthèse des risques, décision de traitement, plan d'action et suivi.

EBIOS RM se distingue par son approche « par la menace » (partir des scénarios d'attaque plausibles) en complément d'une approche « par les actifs ».

2.1 Illustration pédagogique d'un scénario opérationnel (cas fictif)

Pour rendre concret l'atelier 4, considérons une organisation pédagogique fictive, la Direction des Systèmes d'Information Fictive (DSIF), gérant une application de gestion des notes des étudiants. Un scénario opérationnel plausible pourrait se dérouler ainsi : un attaquant opportuniste (source de risque identifiée en atelier 2) envoie un courriel de hameçonnage ciblé à un enseignant disposant d'un accès administrateur à l'application ; l'enseignant, trompé, saisit ses identifiants sur une page frauduleuse ; l'attaquant récupère ces identifiants et se connecte au système ; il modifie des notes ou exfiltre des données personnelles d'étudiants. Ce déroulé, volontairement simple, illustre le niveau de détail attendu en atelier 4 : chaque étape doit être suffisamment concrète pour permettre, en atelier 5, d'identifier des mesures de traitement précises (authentification multifacteur pour les comptes à privilèges, journalisation des modifications de notes, sensibilisation ciblée des enseignants disposant d'accès étendus).

2.2 Points d'attention méthodologiques

EBIOS RM insiste particulièrement sur deux notions qui la distinguent d'approches plus mécaniques :

- **L'écosystème** : une organisation n'est jamais isolée ; ses fournisseurs, prestataires informatiques et partenaires peuvent constituer des points d'entrée indirects vers ses actifs critiques. L'atelier 3 impose explicitement de cartographier ces parties prenantes et d'évaluer leur niveau de menace et de dépendance.
- **La vraisemblance plutôt que la seule probabilité statistique** : en l'absence de données statistiques fiables sur la fréquence d'attaques ciblées (contrairement à des risques industriels bien documentés), EBIOS RM privilégie un jugement argumenté de vraisemblance, construit collectivement par des experts métier et sécurité, plutôt qu'un calcul de probabilité prétendument objectif mais reposant sur des données fragiles.

3. ISO/IEC 27005

Norme internationale de référence pour la gestion des risques SSI, structurée en :

1. Établissement du contexte (critères de risque, périmètre).
2. Appréciation du risque (identification, analyse, évaluation).
3. Traitement du risque.
4. Acceptation du risque.
5. Communication et concertation.
6. Surveillance et revue.

ISO 27005 est le référentiel généralement utilisé pour nourrir le processus de gestion des risques exigé par la clause 6 de l'ISO 27001, dans une logique de certification.

3.1 Articulation avec l'ISO/IEC 27001 et l'Annexe A

L'ISO 27005 ne fonctionne pas seule : elle est conçue pour alimenter le système de management de la sécurité de l'information (SMSI) décrit par l'ISO 27001. Concrètement, l'appréciation des risques menée selon ISO 27005 débouche sur un **plan de traitement du risque**, qui doit se référer aux mesures de sécurité listées dans l'Annexe A de l'ISO 27001 (ou dans l'ISO 27002 pour leur description détaillée). Cette articulation a une conséquence pratique importante pour les organisations visant une certification : chaque mesure de l'Annexe A jugée non applicable doit être explicitement justifiée dans une **Déclaration d'applicabilité** (Statement of Applicability, SoA), document qui fait le pont entre l'analyse de risques et le référentiel de contrôles normalisé.

3.2 Le registre des risques comme livrable central

Au-delà des étapes méthodologiques, ISO 27005 aboutit concrètement à la tenue d'un **registre des risques**, document vivant recensant l'ensemble des risques identifiés, leur évaluation et leur statut de traitement. Un extrait pédagogique simplifié pourrait se présenter ainsi :

ID	Actif concerné	Menace / scénario	Probabilité	Impact	Niveau de risque brut	Mesures existantes	Risque net	Traitement décidé	Responsable	Échéance
R-014	Serveur de messagerie institutionnelle	Compromission par hameçonnage d'un compte administrateur	Probable	Majeur	Élevé	Filtrage antispam basique	Élevé	Réduire (authentification multifacteur)	RSSI	T3
R-027	Base de données des dossiers étudiants	Fuite de données par erreur de configuration d'un accès externe	Possible	Critique	Élevé	Contrôle d'accès par rôle	Modéré	Réduire (audit trimestriel des accès)	DSI	T2
R-033	Site web vitrine de l'établissement	Défacement par vulnérabilité applicative non corrigée	Possible	Modéré	Modéré	Aucune	Modéré	Accepter (impact limité, coût de correction disproportionné)	RSSI	—

Ce registre n'a de valeur que s'il est **maintenu à jour** : réévalué périodiquement (a minima annuellement, mais aussi à chaque changement significatif du système d'information), et présenté aux instances de gouvernance décrites au chapitre 1 pour arbitrage.

4. NIST Risk Management Framework (RMF)

Cadre en sept étapes (Prepare, Categorize, Select, Implement, Assess, Authorize, Monitor), largement utilisé dans le secteur public américain et par des organisations internationales, avec une articulation forte entre catégorisation des systèmes (impact potentiel) et sélection de mesures de sécurité issues d'un catalogue (NIST SP 800-53).

Le RMF se distingue par sa logique de **catégorisation préalable** : avant même d'analyser des scénarios de menace précis, chaque système d'information est classé selon un niveau d'impact potentiel (faible, modéré, élevé) sur trois critères — confidentialité, intégrité, disponibilité. Cette catégorisation détermine ensuite directement l'ensemble minimal de mesures de sécurité à sélectionner dans le catalogue NIST SP 800-53, avant d'être ajustées au contexte spécifique. Cette approche « par catalogue » présente l'avantage d'une grande reproductibilité et facilite les comparaisons entre systèmes similaires, mais elle est parfois critiquée pour son caractère plus mécanique, moins centré sur la créativité des scénarios d'attaque que ne l'est EBIOS RM.

5. Comparaison synthétique

Critère	EBIOS RM	ISO 27005	NIST RMF
Origine	France (ANSSI)	International (ISO)	États-Unis (NIST)
Approche dominante	par la menace (scénarios d'attaque)	par les actifs et le contexte	par la catégorisation et un catalogue de contrôles
Usage typique	administrations, OIV, grandes entreprises francophones	certification ISO 27001	secteur public américain, sous-traitants fédéraux

Ces méthodes ne sont pas mutuellement exclusives : une organisation peut s'appuyer sur ISO 27005 pour son SMSI certifié tout en utilisant les ateliers EBIOS RM pour affiner l'analyse des scénarios d'attaque les plus critiques.

5.1 Autres approches complémentaires à connaître

Au-delà des trois méthodologies principales détaillées ci-dessus, il est utile de connaître, au moins de nom, d'autres approches fréquemment citées dans la littérature et les organisations :

- **MEHARI** (Méthode Harmonisée d'Analyse de Risques), développée par le CLUSIF, propose une approche fondée sur des questionnaires structurés d'évaluation des mesures de sécurité et un calcul semi-quantitatif du risque ; elle a historiquement été très utilisée dans les organisations francophones avant la montée en puissance d'EBIOS RM.
- **OCTAVE** (Operationally Critical Threat, Asset, and Vulnerability Evaluation), développée par le CERT/SEI américain, met l'accent sur une analyse pilotée par les équipes métier elles-mêmes plutôt que par des experts techniques externes, dans une logique d'appropriation interne du risque.

- **FAIR** (Factor Analysis of Information Risk) propose une approche quantitative visant à exprimer le risque en termes financiers (perte annuelle attendue), utile pour dialoguer avec des directions financières habituées à raisonner en probabilités et montants monétaires plutôt qu'en échelles qualitatives.

Ces méthodes ne sont pas approfondies dans ce cours, mais leur existence illustre que le choix méthodologique reste un sujet actif, dépendant de la culture de l'organisation, de son secteur et de la maturité de son dialogue entre sécurité et direction financière.

6. Échelles d'évaluation

Un exemple d'échelle qualitative simple à 4 niveaux, utilisable en TP :

Niveau	Probabilité	Impact
1	Rare	Négligeable
2	Possible	Modéré
3	Probable	Majeur
4	Quasi certain	Critique (met en péril la continuité)

La combinaison probabilité × impact positionne chaque risque sur une **matrice de criticité**, outil central de priorisation (repris en TP2).

6.1 Exemple de matrice de criticité et son usage

Une matrice de criticité croise les niveaux de probabilité (en lignes) et d'impact (en colonnes) pour produire un niveau de risque global, généralement codé par couleur pour faciliter la lecture par un public non spécialiste (vert, jaune, orange, rouge). Un exemple pédagogique construit à partir de l'échelle à 4 niveaux ci-dessus :

Probabilité \ Impact	Négligeable	Modéré	Majeur	Critique
Rare	Faible	Faible	Modéré	Modéré
Possible	Faible	Modéré	Élevé	Élevé
Probable	Modéré	Élevé	Élevé	Critique
Quasi certain	Modéré	Élevé	Critique	Critique

L'intérêt principal de cet outil n'est pas tant sa précision arithmétique — les échelles qualitatives restent par nature approximatives — que sa capacité à **prioriser objectivement** un grand nombre de risques identifiés lors d'un atelier collectif, en évitant que la discussion ne se perde dans des débats interminables sur des risques mineurs au détriment des risques réellement critiques. En pratique, une organisation fixera un seuil (par exemple : tout risque « Élevé » ou « Critique » doit faire l'objet d'un plan de traitement formalisé et d'un suivi en comité de pilotage, tandis qu'un risque « Faible » peut être accepté sans formalisme excessif).

6.2 Limites et précautions d'usage des échelles qualitatives

Les échelles qualitatives, malgré leur simplicité d'usage, comportent des biais qu'il convient de connaître pour les utiliser à bon escient en TP comme en pratique professionnelle :

- **Le biais d'ancrage** : les participants à un atelier d'évaluation ont tendance à converger vers les niveaux intermédiaires par prudence, ce qui peut aplatir artificiellement les écarts entre risques réellement très différents.
- **Le manque de granularité aux extrêmes** : deux risques classés tous deux « Critique » peuvent en réalité avoir des ordres de grandeur d'impact très différents (un impact critique pouvant être dix fois supérieur à un autre) sans que la matrice qualitative ne le distingue.
- **La subjectivité de l'évaluation** : la probabilité et l'impact restent des jugements d'experts, potentiellement divergents selon les participants ; c'est pourquoi les ateliers collectifs (comme ceux d'EBIOS RM) sont préférables à une évaluation individuelle isolée, afin de confronter les points de vue et d'aboutir à un consensus argumenté.

À retenir

- Risque = fonction de la probabilité d'occurrence et de l'impact, jamais l'un sans l'autre ; il convient de distinguer risque brut, risque net et risque résiduel selon l'étape du traitement.
- EBIOS RM structure l'analyse « par la menace » en cinq ateliers, en portant une attention particulière à l'écosystème (fournisseurs, partenaires) ; ISO 27005 structure l'analyse « par le contexte et les actifs » en six étapes et s'articule directement avec le SMSI de l'ISO 27001 via la Déclaration d'applicabilité.

- Le choix de la méthode dépend souvent du contexte réglementaire et sectoriel de l'organisation ; d'autres approches (MEHARI, OCTAVE, FAIR) existent et répondent à des besoins spécifiques, notamment la quantification financière du risque.
- Le registre des risques et la matrice de criticité sont les deux outils opérationnels centraux qui traduisent la méthodologie choisie en un support de priorisation et de suivi concret, mais leurs limites (biais d'ancrage, subjectivité) doivent être connues et discutées collectivement.

Chapitre 3 — Traitement du risque, PSSI et continuité d'activité

1. Les quatre stratégies de traitement du risque

Stratégie	Principe	Exemple
Éviter	supprimer l'activité ou l'actif générant le risque	ne pas exposer un service inutile sur Internet
Réduire (atténuer)	mettre en œuvre des mesures pour diminuer probabilité et/ou impact	déployer un pare-feu, chiffrer les données
Transférer (partager)	déplacer une partie de l'impact vers un tiers	souscrire une cyber-assurance, externaliser à un prestataire avec obligations contractuelles
Accepter	assumer consciemment le risque, en général si le coût du traitement dépasse l'impact potentiel	accepter un risque résiduel faible après mise en œuvre des mesures principales

Le choix résulte d'un arbitrage coût/bénéfice, validé par le niveau de gouvernance approprié (la direction pour les risques majeurs).

1.1 Combiner les stratégies plutôt que choisir une seule option

Dans la pratique, ces quatre stratégies ne sont pas exclusives les unes des autres : elles se combinent fréquemment pour un même risque. Prenons l'exemple d'un risque de compromission d'un serveur applicatif exposé sur Internet : une organisation peut simultanément **réduire** le risque (durcissement du serveur, pare-feu applicatif, correctifs réguliers), **transférer** une partie de l'impact financier résiduel (cyber-assurance couvrant les frais de remédiation), et **accepter** ce qui reste après ces mesures (le risque résiduel qu'une vulnérabilité inconnue de type « zero-day » soit exploitée malgré tout). La stratégie d'**évitement** pur reste souvent la moins utilisée en pratique, car elle suppose de renoncer à une activité ou un service ayant une valeur métier — un arbitrage rarement neutre, à ne prendre qu'après avoir sérieusement évalué le coût d'opportunité pour l'organisation.

1.2 L'acceptation du risque : une décision qui doit rester traçable

L'acceptation du risque est souvent la stratégie la moins bien maîtrisée en pratique, car elle est parfois confondue avec une simple absence de décision (« on ne fait rien parce que personne n'a tranché ») plutôt qu'avec une décision explicite et documentée. Une acceptation de risque digne de ce nom doit répondre à plusieurs exigences :

- Elle doit être **formalisée par écrit**, avec une justification claire (coût de traitement disproportionné par rapport à l'impact, absence de solution technique satisfaisante, échéance de traitement planifiée mais non encore atteinte).
- Elle doit être **validée par une autorité compétente**, dont le niveau hiérarchique est proportionné à la criticité du risque accepté — un risque mineur peut être accepté par un responsable opérationnel, tandis qu'un risque majeur doit remonter à la direction générale (voir chapitre 1).
- Elle doit être **revue périodiquement** : un risque accepté aujourd'hui peut devenir inacceptable demain si son contexte évolue (nouvelle vulnérabilité découverte, changement réglementaire, évolution de la criticité de l'actif concerné).

Une organisation qui accumule des risques acceptés de manière informelle, sans traçabilité ni révision, s'expose à un phénomène bien connu des auditeurs : la « dérive silencieuse » du niveau de risque global, qui n'est révélée qu'au moment d'un incident.

2. La Politique de Sécurité des Systèmes d'Information (PSSI)

La PSSI est le document de référence formalisant les orientations stratégiques et les règles de sécurité applicables à l'ensemble de l'organisation. Elle se décline généralement en plusieurs niveaux :

1. **Politique générale** : principes, engagement de la direction, périmètre (quelques pages, stable dans le temps).
2. **Politiques thématiques** : contrôle d'accès, gestion des mots de passe, usage des équipements mobiles, télétravail, gestion des tiers.
3. **Procédures opérationnelles** : instructions détaillées d'application (gestion des incidents, sauvegardes).

Structure type d'une politique générale

- Objet et périmètre.
- Engagement de la direction.
- Organisation et responsabilités (rôles définis au chapitre 1).
- Principes directeurs (moindre privilège, défense en profondeur, séparation des tâches).
- Gestion des risques et conformité.
- Sanctions en cas de non-respect.

- Modalités de révision.

Une PSSI efficace est **connue, appliquée et révisée régulièrement** — une politique rédigée puis jamais diffusée ni actualisée est un signe classique d'immaturité relevé en audit organisationnel.

2.1 Extrait illustratif d'une politique thématique (exemple pédagogique)

Pour rendre plus concret ce que recouvre une « politique thématique », voici un extrait fictif simplifié d'une politique de gestion des mots de passe, tel qu'on pourrait le trouver dans une organisation pédagogique :

Politique thématique — Gestion des mots de passe (extrait, exemple pédagogique)

1. *Objet* : la présente politique fixe les exigences minimales applicables à tout mot de passe utilisé pour accéder aux systèmes d'information de l'établissement.
2. *Exigences de robustesse* : tout mot de passe doit comporter un nombre minimal de caractères et combiner plusieurs catégories (majuscules, minuscules, chiffres, caractères spéciaux), conformément aux recommandations en vigueur.
3. *Authentification renforcée* : l'authentification multifacteur est obligatoire pour tout compte disposant de privilèges d'administration.
4. *Confidentialité* : un mot de passe est strictement personnel et ne doit jamais être partagé, y compris avec un collègue ou un service support.
5. *Gestion des incidents* : toute suspicion de compromission d'un mot de passe doit être signalée sans délai au service compétent, qui procède à sa réinitialisation immédiate.
6. *Révision* : la présente politique est revue annuellement par le RSSI et approuvée par la direction.

Cet exemple, volontairement simplifié, illustre le niveau de précision attendu d'une politique thématique : suffisamment concret pour être applicable et contrôlable, sans pour autant se substituer à une procédure opérationnelle détaillée (qui définirait, par exemple, les paramètres techniques exacts de complexité configurés dans l'annuaire d'entreprise).

2.2 Diffusion, appropriation et sanctions : les conditions d'efficacité réelle

La rédaction d'une PSSI n'est que la première étape d'un processus plus large, souvent négligé par les organisations peu matures :

- **La diffusion** doit être organisée activement (formation à l'arrivée, campagnes de rappel, intégration dans le règlement intérieur ou les contrats de travail) plutôt que de reposer sur la simple mise à disposition d'un document sur un intranet que personne ne consulte spontanément.
- **L'appropriation** suppose que les principes de la PSSI soient traduits en gestes concrets et compréhensibles par chaque catégorie de collaborateurs, plutôt que présentés comme un texte juridique abstrait.
- **Les sanctions** en cas de non-respect doivent être proportionnées, connues à l'avance, et appliquées de manière cohérente — une politique qui prévoit des sanctions jamais appliquées perd rapidement toute crédibilité auprès des collaborateurs.
- **La révision périodique** doit tenir compte à la fois de l'évolution des menaces (une politique rédigée avant la généralisation du télétravail, par exemple, doit être mise à jour pour en tenir compte) et des retours d'expérience issus des incidents et des audits.

3. Plan de Continuité d'Activité (PCA) et Plan de Reprise d'Activité (PRA)

- **PCA** : ensemble des dispositions visant à assurer, en cas de crise majeure, le maintien (éventuellement dégradé) des activités essentielles de l'organisation.
- **PRA** : volet plus spécifiquement technique du PCA, centré sur la reprise des systèmes d'information après un sinistre.

Notions clés

Indicateur	Définition
RTO (Recovery Time Objective)	durée maximale d'interruption acceptable avant reprise du service
RPO (Recovery Point Objective)	perte de données maximale acceptable, exprimée en temps (ex. RPO de 4h = perte maximale des 4 dernières heures de données)

Ces deux indicateurs déterminent directement l'architecture de résilience à mettre en œuvre (fréquence de sauvegarde, site de secours actif/passif, réplication temps réel).

Exemple illustratif de déclinaison RTO/RPO par processus (cas pédagogique)

Tous les processus d'une organisation n'ont pas la même criticité, et un PCA efficace différencie explicitement ses exigences selon les processus métier concernés, plutôt que d'appliquer un objectif uniforme à l'ensemble du système d'information — ce qui serait à la fois coûteux

(pour les processus peu critiques) et insuffisant (pour les processus les plus sensibles). Un exemple pédagogique simplifié, pour une organisation fictive :

Processus	Criticité	RTO cible	RPO cible	Stratégie de résilience associée
Système de paie	Critique	quelques heures	quasi nul	site de secours actif, réplication continue
Messagerie institutionnelle	Élevée	moins d'une journée	quelques heures	sauvegardes fréquentes, restauration rapide
Portail pédagogique en ligne	Modérée	quelques jours	une journée	sauvegardes quotidiennes, reprise sur site secondaire passif
Application de gestion des archives historiques	Faible	plusieurs semaines	une semaine	sauvegardes hebdomadaires

Ce tableau illustre un principe important : plus le RTO et le RPO cibles sont courts, plus l'architecture technique associée est coûteuse (réplication en temps réel, site de secours actif nécessitant une infrastructure dupliquée). La détermination du RTO/RPO n'est donc pas un exercice purement technique : c'est un arbitrage économique, validé par les propriétaires de processus métier et la direction, qui doit mettre en balance le coût de la résilience et le coût d'une interruption non maîtrisée.

Étapes d'élaboration d'un PCA

1. Analyse d'impact sur l'activité (BIA — Business Impact Analysis) : identifier les processus critiques et leur RTO/RPO cible.
2. Définition des stratégies de continuité (site de secours, télétravail de crise, procédures dégradées).
3. Rédaction des plans opérationnels (qui fait quoi, avec quelles ressources).
4. Tests réguliers (exercices de crise, tests techniques de bascule).
5. Mise à jour continue.

Un PCA non testé est un PCA dont l'efficacité réelle est inconnue : les tests réguliers sont aussi importants que la rédaction du plan lui-même.

Typologie des tests de PCA/PRA

Les tests de continuité peuvent prendre différentes formes, de complexité et de réalisme croissants, qu'il est utile de distinguer :

- **Test documentaire (walkthrough)** : relecture collective du plan par les parties prenantes, permettant de vérifier sa cohérence sans mobiliser de ressources techniques ; peu coûteux mais peu représentatif des difficultés réelles.
- **Exercice de simulation (tabletop exercise)** : les acteurs clés (RSSI, DSI, direction, communication) réagissent oralement à un scénario de crise fictif présenté par un animateur, sans bascule technique réelle ; permet de tester la coordination et la prise de décision.
- **Test technique partiel** : bascule effective d'un composant limité (par exemple, restauration d'une sauvegarde sur un environnement isolé) pour valider la faisabilité technique d'une procédure précise.
- **Test grandeur réelle (bascule complète)** : activation effective du site de secours et des procédures dégradées, dans des conditions proches d'une crise réelle ; le plus représentatif mais aussi le plus coûteux et risqué à organiser, généralement réservé aux processus les plus critiques et planifié avec grand soin pour ne pas perturber l'activité réelle.

Une pratique de maturité consiste à alterner ces différents types de test sur un cycle pluriannuel, plutôt que de se limiter systématiquement au test documentaire le moins exigeant — une tentation fréquente compte tenu du coût et de la complexité d'organisation des tests grandeur réelle.

4. Gestion de crise cyber

Distincte mais complémentaire du PCA/PRA : une cellule de crise dédiée (souvent associant RSSI, DSI, communication, juridique, direction) doit pouvoir être activée rapidement en cas d'incident majeur (ex. rançongiciel), avec des procédures de décision pré-établies (isoler, communiquer, notifier les autorités compétentes le cas échéant).

4.1 Les phases typiques d'une gestion de crise cyber

Une gestion de crise structurée s'organise généralement autour de phases successives, qu'il est utile de mémoriser pour comprendre l'articulation entre réaction technique et pilotage de gouvernance :

1. **Détection et qualification** : un événement est détecté (alerte technique, signalement d'un utilisateur, notification d'un tiers) et qualifié comme incident de sécurité potentiellement majeur, déclenchant l'activation de la cellule de crise.
2. **Endiguement (containment)** : mesures immédiates visant à limiter la propagation de l'incident (isolement de systèmes compromis, coupure de connexions réseau suspectes), en arbitrant entre l'urgence technique et la préservation des preuves nécessaires à l'investigation ultérieure.

3. **Investigation et éradication** : analyse approfondie de l'origine et de l'étendue de la compromission, puis suppression effective de la cause (réinstallation de systèmes compromis, révocation d'identifiants exposés, correction de la vulnérabilité exploitée).
4. **Communication** : information coordonnée des parties prenantes internes (direction, collaborateurs) et externes (clients, partenaires, autorités compétentes selon les obligations réglementaires applicables), pilotée conjointement par la communication, le juridique et le RSSI pour éviter les messages contradictoires.
5. **Reprise d'activité** : retour progressif à un fonctionnement normal, en s'appuyant si nécessaire sur le PCA/PRA lorsque l'incident a affecté la disponibilité des systèmes.
6. **Retour d'expérience (post-mortem)** : analyse a posteriori de la crise, sans recherche de responsabilité individuelle punitive mais dans une logique d'amélioration continue, débouchant sur des actions correctives qui alimentent le registre des risques (chapitre 2) et, le cas échéant, une révision de la PSSI.

Ce découpage en phases rappelle que la gestion de crise n'est pas qu'une affaire technique : la coordination entre acteurs très différents (techniques, juridiques, communication, direction) est souvent le facteur le plus déterminant de la capacité d'une organisation à traverser une crise cyber sans dommage disproportionné, davantage encore que la seule sophistication des outils techniques déployés.

À retenir

- Quatre stratégies de traitement du risque : éviter, réduire, transférer, accepter — le choix relève d'un arbitrage validé par la gouvernance, et ces stratégies se combinent souvent pour un même risque plutôt que de s'exclure mutuellement.
- L'acceptation du risque doit être une décision explicite, tracée, validée au bon niveau hiérarchique et revue périodiquement — jamais une absence de décision par défaut.
- La PSSI se décline en plusieurs niveaux, de la politique générale aux procédures opérationnelles, et doit être vivante (diffusée, appropriée, appliquée, révisée) ; une politique non diffusée ni actualisée est un signe classique d'immaturité.
- RTO et RPO traduisent en exigences concrètes la criticité des processus métier, doivent être différenciés selon les processus, et dimensionnent le PCA/PRA ; un plan non testé reste théorique, et les modalités de test (documentaire, simulation, technique partiel, grandeur réelle) doivent être variées dans le temps.
- La gestion de crise cyber s'organise en phases successives (détection, endiguement, investigation, communication, reprise, retour d'expérience) qui mobilisent des compétences bien au-delà du seul champ technique.

Chapitre 4 — Pilotage, indicateurs et conformité réglementaire

1. Pourquoi piloter par les indicateurs

Une gouvernance SSI mature ne se limite pas à produire des documents (PSSI, analyses de risque) : elle démontre, dans la durée, une amélioration mesurable. Les indicateurs permettent de communiquer objectivement avec la direction, de détecter une dérive avant qu'elle ne devienne un incident, et de justifier les investissements.

Ce chapitre clôt logiquement le module : les chapitres précédents ont posé le cadre de gouvernance (chapitre 1), la méthodologie d'analyse des risques (chapitre 2) et les modalités de traitement (chapitre 3). Le pilotage par indicateurs est ce qui referme le cycle PDCA introduit au chapitre 1 : il permet de vérifier, avec des données plutôt que des impressions, que les décisions prises produisent réellement les effets attendus, et d'alimenter le cycle suivant sur des bases objectives plutôt que sur une simple reconduction des pratiques existantes.

1.1 Les fonctions d'un indicateur, au-delà du simple constat

Un indicateur SSI bien conçu remplit simultanément plusieurs fonctions, qu'il est utile de distinguer explicitement pour éviter de produire des indicateurs purement décoratifs :

- **Une fonction de suivi** : mesurer l'évolution d'un phénomène dans le temps (une tendance est presque toujours plus informative qu'une valeur isolée à un instant donné).
- **Une fonction d'alerte** : signaler un dépassement de seuil qui appelle une action corrective, idéalement avant qu'un incident ne survienne plutôt qu'après coup.
- **Une fonction de justification** : documenter, à l'attention de la direction ou d'un auditeur externe, que les moyens alloués produisent un effet mesurable, ce qui légitime les demandes de budget futures.
- **Une fonction de comparaison** : permettre de se situer par rapport à un objectif interne, à une valeur cible fixée en gouvernance, ou éventuellement à d'autres entités comparables lorsque des données de référence existent.

Un même indicateur ne remplit pas nécessairement toutes ces fonctions à la fois ; il est donc utile, lors de la conception d'un tableau de bord, de clarifier explicitement à quelle fonction chaque indicateur retenu répond.

2. Caractéristiques d'un bon indicateur

Un indicateur utile est généralement décrit par les critères **SMART** : Spécifique, Mesurable, Atteignable, Réaliste, Temporellement défini. Il doit surtout être **actionnable** : un indicateur qui ne débouche sur aucune décision possible n'a pas d'intérêt opérationnel.

2.1 Pièges fréquents dans la conception d'indicateurs

L'expérience montre que certains écueils reviennent fréquemment dans la construction de tableaux de bord SSI, et qu'il est utile de connaître pour les éviter :

- **La multiplication d'indicateurs peu significatifs** : un tableau de bord comportant plusieurs dizaines d'indicateurs devient illisible et dilue l'attention de la direction sur ce qui compte réellement ; mieux vaut un nombre restreint d'indicateurs réellement pilotés qu'une liste exhaustive jamais analysée en profondeur.
- **La confusion entre indicateur d'activité et indicateur de résultat** : compter le nombre de formations de sensibilisation dispensées (indicateur d'activité) est différent de mesurer le taux de clic sur une campagne de simulation de phishing (indicateur de résultat, qui reflète mieux l'effet réel de la sensibilisation).
- **L'absence de cible associée** : un indicateur affiché sans valeur de référence ni seuil d'alerte ne permet pas de savoir si la situation constatée est satisfaisante ou préoccupante.
- **Le choix d'indicateurs valorisants plutôt qu'informatifs** : la tentation de ne présenter que des indicateurs favorables à l'équipe sécurité (en omettant ceux qui révéleraient des difficultés) nuit à la crédibilité du dispositif de pilotage sur le long terme et peut retarder la détection de problèmes réels.

3. Exemples d'indicateurs SSI

Catégorie	Exemple d'indicateur
Vulnérabilités	délai moyen d'application des correctifs critiques (patch management)
Incidents	nombre d'incidents de sécurité déclarés par mois, temps moyen de détection (MTTD), temps moyen de résolution (MTTR)
Sensibilisation	taux de clics sur des campagnes de simulation de phishing

Catégorie	Exemple d'indicateur
Conformité	pourcentage d'exigences ISO 27001 couvertes, nombre de non-conformités ouvertes
Continuité	résultat des derniers tests de PCA/PRA (RTO/RPO atteints ou non)
Accès	nombre de comptes à privilèges, délai de révocation des accès après départ d'un collaborateur

3.1 Exemple illustratif de fiche d'indicateur (cas pédagogique)

Pour qu'un indicateur soit véritablement exploitable, il est recommandé de le documenter au-delà de sa simple valeur chiffrée, dans une fiche qui en précise le calcul et l'usage attendu. Un exemple pédagogique fictif :

Fiche indicateur — Délai moyen d'application des correctifs critiques

- *Définition* : nombre moyen de jours écoulés entre la publication d'un correctif de sécurité classé critique par l'éditeur et son déploiement effectif sur les systèmes concernés.
- *Source de données* : outil de gestion des correctifs (patch management) et inventaire des actifs.
- *Fréquence de calcul* : mensuelle.
- *Cible fixée par la gouvernance* : délai inférieur à un seuil défini en comité de pilotage, cohérent avec l'appétence au risque de l'organisation.
- *Seuil d'alerte* : dépassement du seuil sur deux mois consécutifs déclenche une analyse de cause et un plan d'action présenté en comité de pilotage.
- *Limite connue* : l'indicateur ne distingue pas, dans sa version simple, les systèmes critiques des systèmes secondaires ; une déclinaison par criticité d'actif est recommandée pour affiner le pilotage.

Documenter ainsi chaque indicateur clé évite les désaccords récurrents sur sa méthode de calcul et facilite sa reprise par un successeur du RSSI, un enjeu de continuité souvent sous-estimé.

3.2 Exemple d'évolution d'indicateurs sur plusieurs périodes

Au-delà de la valeur instantanée, la tendance dans le temps est souvent l'information la plus utile pour la direction. Un exemple pédagogique simplifié de suivi trimestriel :

Indicateur	T1	T2	T3	T4	Cible	Tendance
Délai moyen de correction des vulnérabilités critiques (jours)	21	17	14	12	≤ 15	en amélioration
Nombre d'incidents de sécurité déclarés	6	4	5	3	—	stable à en amélioration
Taux de clic sur simulation de phishing	22 %	18 %	15 %	13 %	≤ 10 %	en amélioration, cible non encore atteinte
Non-conformités ouvertes (audit interne)	9	11	7	5	0	en amélioration

Ce type de tableau, même construit sur des données pédagogiques fictives, illustre l'intérêt du suivi dans la durée : il permet de distinguer une variation ponctuelle sans conséquence d'une tendance structurelle qui appelle une action de fond, et de démontrer concrètement à la direction l'effet des mesures prises (par exemple, une baisse continue du taux de clic sur les campagnes de simulation de phishing peut être mise en regard d'un programme de sensibilisation renforcé).

4. Tableau de bord SSI

Un tableau de bord synthétise ces indicateurs pour différents publics :

- **Vision direction** : quelques indicateurs agrégés, tendance (amélioration/dégradation), niveau de risque global.
- **Vision RSSI/opérationnelle** : indicateurs détaillés par domaine, permettant d'identifier les points d'action prioritaires.

La fréquence de mise à jour (mensuelle, trimestrielle) et le format (comité de pilotage, revue de direction) doivent être définis dans la gouvernance elle-même.

4.1 Adapter la forme du tableau de bord à son public

Un même ensemble de données sous-jacentes peut être présenté de façon très différente selon le public visé, et cette adaptation est elle-même un exercice de gouvernance à part entière :

- Pour la **direction générale**, la forme privilégie la synthèse visuelle (codes couleur, tendances, un nombre restreint d'indicateurs clés) et la mise en perspective avec les enjeux métier (impact potentiel sur la continuité des opérations, coûts évités, position par rapport aux obligations réglementaires), plutôt que le détail technique.

- Pour le **comité de pilotage SSI**, le tableau de bord peut être plus détaillé, décliné par domaine (vulnérabilités, incidents, conformité, continuité), avec des indicateurs permettant d'identifier précisément où porter l'effort.
- Pour les **équipes opérationnelles**, un niveau de détail encore plus fin est pertinent (par exemple, la liste nominative des systèmes non corrigés), qui n'aurait pas de sens présenté tel quel en revue de direction.

Cette hiérarchisation de l'information, du détail opérationnel vers la synthèse stratégique, reprend directement la distinction des trois niveaux de gouvernance (stratégique, tactique, opérationnel) introduite au chapitre 1 : chaque niveau doit recevoir une information calibrée à son rôle dans la prise de décision, ni trop pauvre pour éclairer utilement, ni trop riche pour rester exploitable dans le temps disponible.

5. Conformité réglementaire : panorama non exhaustif

Cadre réglementaire	Portée	Point clé
RGPD (et lois nationales équivalentes de protection des données)	données à caractère personnel	notification des violations, analyse d'impact (AIPD) pour les traitements à risque
Réglementations sectorielles (banque, assurance, santé, télécoms)	secteurs régulés	exigences souvent renforcées (ex. résilience opérationnelle dans le secteur financier)
Réglementations nationales de cybersécurité (souvent inspirées de directives régionales)	opérateurs d'importance vitale ou essentiels	obligations de déclaration d'incident, exigences techniques minimales
Exigences contractuelles	relations clients/fournisseurs	souvent alignées sur ISO 27001 ou des questionnaires de sécurité spécifiques

La conformité n'est pas un objectif en soi mais un sous-ensemble de la gestion des risques : une organisation conforme n'est pas nécessairement sécurisée, et inversement une organisation bien sécurisée doit néanmoins documenter sa conformité pour ses obligations légales et contractuelles.

5.1 Le risque du « théâtre de conformité »

Un écueil bien documenté dans la littérature professionnelle mérite d'être souligné : le « théâtre de conformité » (compliance theater), c'est-à-dire une situation où l'organisation consacre l'essentiel de son énergie à produire de la documentation et à cocher des cases lors d'audits, sans que cela se traduise par une amélioration réelle du niveau de sécurité effectif. Ce risque est particulièrement présent lorsque la conformité est pilotée en silo, déconnectée du processus de gestion des risques : une checklist de conformité peut être remplie de bonne foi tout en laissant de côté des risques réels non couverts par le référentiel appliqué. La bonne pratique consiste à faire de la conformité un **sous-produit** d'une gestion des risques bien menée (les mesures issues du traitement du risque couvrent naturellement une large part des exigences de conformité), plutôt que l'inverse (une conformité poursuivie pour elle-même, indépendamment d'une analyse réelle des risques encourus).

5.2 Exemple de suivi de conformité à un référentiel (cas pédagogique)

Le suivi de conformité à un référentiel comme l'ISO 27001 peut se matérialiser par un tableau de suivi des exigences, décliné par domaine de contrôle. Un extrait pédagogique simplifié :

Domaine de contrôle	Exigences applicables	Exigences couvertes	Taux de couverture	Non-conformités ouvertes
Politique de sécurité	4	4	100 %	0
Gestion des accès	12	9	75 %	2
Gestion des incidents	8	8	100 %	0
Continuité d'activité	6	3	50 %	3
Gestion des fournisseurs	7	5	71 %	1

Ce type de tableau permet d'identifier immédiatement les domaines nécessitant un effort prioritaire (ici, la continuité d'activité, en cohérence avec le chapitre 3) et de nourrir directement le plan d'action présenté en revue de direction, plutôt que de se limiter à une appréciation globale et peu actionnable du type « l'organisation est conforme à 79 % ».

6. Revue de direction et amélioration continue

L'ISO 27001 impose une revue de direction périodique du SMSI, qui doit examiner : les résultats des audits internes/externes, l'état d'avancement du traitement des risques, les indicateurs de performance, les retours des parties intéressées, et déboucher sur des décisions (allocation de ressources, ajustement des priorités). C'est le point de bouclage du cycle PDCA introduit au chapitre 1.

6.1 Ordre du jour type d'une revue de direction (exemple pédagogique)

Pour rendre concrète cette instance centrale de la gouvernance, voici un exemple pédagogique de trame d'ordre du jour, tel qu'on pourrait le retrouver dans une organisation appliquant l'ISO 27001 :

1. Suivi des décisions de la revue de direction précédente (actions réalisées, en cours, en retard).
2. Évolution du contexte interne et externe susceptible d'affecter le SMSI (nouvelle réglementation, changement organisationnel, nouvelle menace identifiée).
3. Résultats des audits internes et externes réalisés depuis la dernière revue.
4. Retours des parties intéressées pertinentes (clients, fournisseurs, régulateurs).
5. État du registre des risques : nouveaux risques identifiés, évolution des risques existants, efficacité des mesures de traitement (chapitres 2 et 3).
6. Synthèse des indicateurs de performance et de conformité (sections précédentes de ce chapitre).
7. Opportunités d'amélioration continue identifiées.
8. Décisions : allocation de ressources, ajustement des priorités, validation d'acceptations de risque majeures (chapitre 3).

Cette trame illustre concrètement comment l'ensemble des notions vues dans ce module — gouvernance et rôles (chapitre 1), méthodologie de gestion des risques (chapitre 2), traitement et continuité (chapitre 3), pilotage et conformité (chapitre 4) — converge vers une même instance de décision périodique, qui est le véritable moteur de l'amélioration continue d'une gouvernance SSI mature.

6.2 De la revue de direction au cycle suivant

Les décisions issues de la revue de direction ne sont pas une fin en soi : elles doivent explicitement réalimenter le cycle de gouvernance décrit dès le premier chapitre. Un ajustement de priorité décidé en revue de direction peut ainsi se traduire par une révision du registre des risques, une mise à jour de la PSSI, une allocation budgétaire nouvelle pour un projet de mise en conformité, ou encore la définition de nouveaux indicateurs à suivre lors du cycle suivant. C'est cette boucle continue, et non une succession de documents produits une fois pour toutes, qui caractérise une gouvernance de la sécurité de l'information réellement mature.

À retenir

- Un indicateur SSI doit être actionnable, pas seulement descriptif ; il remplit une ou plusieurs fonctions précises (suivi, alerte, justification, comparaison) qu'il est utile d'identifier explicitement lors de sa conception.
- Le tableau de bord se décline selon le public (direction, comité de pilotage, opérationnel) pour rester pertinent à chaque niveau, en écho aux trois niveaux de gouvernance introduits au chapitre 1.
- La conformité réglementaire est une composante de la gestion des risques, pas un objectif indépendant ; elle se pilote au même titre que les autres indicateurs, et doit éviter l'écueil du « théâtre de conformité » en restant ancrée dans une gestion des risques réelle.
- La revue de direction est le point de bouclage du cycle PDCA : elle transforme les indicateurs, les résultats d'audit et l'état du registre des risques en décisions concrètes, qui relancent à leur tour le cycle de gouvernance.